



Политика безопасности

Поддерживаемые версии

Мы обеспечиваем обновления безопасности для следующих версий:

Версия	Поддержка безопасности
0.2.x	✓ Да
< 0.2	✗ Нет



Сообщение об уязвимостях

Если вы обнаружили уязвимость в **SSVproff Panel**, пожалуйста, **не создавайте публичный Issue**.

Как сообщить

1. **Отправьте сообщение через GitHub Security Advisory:**

- Перейдите на вкладку [Security](https://github.com/Serg2206/ssvproff-panel/security/advisories) (<https://github.com/Serg2206/ssvproff-panel/security/advisories>)
- Нажмите **“Report a vulnerability”**

2. **Или напишите напрямую:**

- Email: [добавьте свой email, если хотите]
- Укажите в теме: `[SECURITY] SSVproff Panel`

Что включить в отчёт

- Описание уязвимости
- Шаги для воспроизведения
- Потенциальное влияние (какие данные под угрозой)
- Ваши предложения по исправлению (если есть)

Что ожидать

- **Подтверждение получения:** в течение 48 часов
 - **Оценка серьёзности:** в течение 7 дней
 - **Исправление:** в зависимости от серьёзности (критические — в течение 14 дней)
 - **Публичное раскрытие:** после выпуска исправления
-

Принципы безопасности

Что делаем для защиты

1. Только localhost:

- Панель работает только на `127.0.0.1`
- Не слушает внешние интерфейсы (`0.0.0.0`)

2. Аутентификация:

- Доступ по паролю (`APP_PASSWORD`)
- Секретный ключ для сессий (`APP_SECRET`)
- Сессии с ограниченным временем жизни

3. Whitelist команд:

- Выполняются только команды из `flows/SSVproff.ps1`
- Нет возможности выполнить произвольный код

4. Логирование:

- Все действия записываются в лог
- Логи помогают отследить подозрительную активность

5. Автоматические обновления:

- Dependabot проверяет зависимости еженедельно
- CodeQL анализирует код на уязвимости

6. Изоляция секретов:

- `.env` файл не коммитится в Git
- Секреты не попадают в логи
- `.gitignore` блокирует чувствительные файлы

Рекомендации пользователям

Обязательно:

1. Используйте сильные пароли:

- `APP_PASSWORD` : минимум 16 символов, случайная строка
- `APP_SECRET` : генерируйте через `openssl rand -hex 32`

2. Не публикуйте панель в интернет:

- Не запускайте на `0.0.0.0`
- Не открывайте порт 8000 в роутере
- Не используйте ngrok/туннели

3. Обновляйте зависимости:

- Следите за Dependabot alerts
- Регулярно обновляйте `requirements.txt` и `package.json`

4. Защищайте `.env` файл:

- Никогда не коммитьте его в Git
- Не делитесь содержимым
- Используйте права доступа: `chmod 600 .env`

5. Проверьте команды в `flows/SSVproff.ps1` :

- Добавляйте только проверенные команды
- Избегайте команд с прямым доступом к системе
- Не используйте `Invoke-Expression` с пользовательским вводом

Известные ограничения

Текущие ограничения безопасности

1. Нет защиты от CSRF:

- Панель работает на localhost, CSRF-атаки маловероятны
- Если нужна публичная версия — потребуются CSRF-токены

2. Нет rate limiting:

- На localhost не критично
- При публичном использовании — добавьте `slowapi` или аналог

3. Логи не шифруются:

- Логи (`ui_actions.log` , `ui_actions.csv`) хранятся в plaintext
- Защитите их правами доступа: `chmod 600 *.log *.csv`

4. PowerShell команды выполняются с правами пользователя:

- Не запускайте панель от имени администратора
- Используйте отдельного пользователя с ограниченными правами

Чеклист безопасности

Перед использованием панели в продакшене:

- ☐ Изменён `APP_PASSWORD` (не `password`)
- ☐ Сгенерирован случайный `APP_SECRET`
- ☐ `.env` файл защищён (`chmod 600`)
- ☐ Панель запущена на `127.0.0.1` (не `0.0.0.0`)
- ☐ Проверены команды в `flows/SSVproff.ps1`
- ☐ Обновлено зависимости (Backend и Frontend)
- ☐ Включены Dependabot Alerts в репозитории
- ☐ Включён CodeQL в репозитории
- ☐ Настроен мониторинг логов

Обновления безопасности

Как применять

1. Обновите код:

```
bash
git pull origin main
```

1. Обновите Backend зависимости:

```
bash
cd panel/backend
pip install -r requirements.txt --upgrade
```

1. Обновите Frontend зависимости:

```
bash
cd panel/frontend
npm install
npm audit fix
```

1. Перезапустите панель:

```
powershell
.\start_panel.ps1
```

Контакты

Security Team: [@Serg2206](https://github.com/Serg2206) (<https://github.com/Serg2206>)

Security Policy: <https://github.com/Serg2206/ssvproff-panel/security/policy>

Security Advisories: <https://github.com/Serg2206/ssvproff-panel/security/advisories>

Спасибо за помощь в поддержании безопасности проекта! 🙏